

Introduction

While security is the shared responsibility of all personnel in an organization, an organization's leadership plays a unique and important role in achieving and maintaining a strong security posture. While dedicated information security analysts are responsible for implementing an information security strategy, leadership sets the tone and provides the authority and resources to implement that strategy. An important first step in implementing a security strategy is to clearly state the goals of the security strategy. An IT security policy does just that. An organization's IT security policy communicates what leadership's desires, which in turn define what security means to the organization.

Although there may be a main purpose for any policy, an IT security policy is not a single, monolithic document. It is more accurately described as an infrastructure. An IT security policy consists of multiple documents with different focuses and audiences. At the highest level, organizational level policy is a collection of documents that sets the organization's tone and culture. The next level of policy is the functional policy. A functional policy provides direction to management in specific areas. Some examples of functional policies include the following:

- Acceptable use
- Antivirus
- Email
- Firewall
- Wireless
- Mobile devices

The lower levels of policy are made up of different documents that provide guidance on implementing policy. These supporting documents can include any of the following:

- Standards – Mandated requirements used to address security risk.
- Procedures – Step-by-step systematic actions to accomplish one or more security requirements.
- Baselines – Collections of configurations settings that adhere to an organization's security policy.
- Guidelines – Recommendations to help security personnel implement security solutions.

In this lab, you will practice implementing several different functional security policies. You will use Microsoft's Group Policy Management Console to implement password protection and antivirus policies. You will also learn how you can implement multiple policies using a Microsoft-issued security

baseline and explore best practices for a mobile device security policy.

Lab Overview

SECTION 1 of this lab has two parts, which should be completed in the order specified.

1. In the first part of the lab, you will use the Group Policy Management Console to implement a password protection policy.
2. In the second part of the lab, you will use the Group Policy Management Console to implement an antivirus policy.

SECTION 2 of this lab allows you to apply what you learned in **SECTION 1** with less guidance and different deliverables, as well as some expanded tasks and alternative methods. You will implement multiple policies using a Windows security baseline and configure an Android mobile device to comply with a mobile device security policy.

Finally, you will explore the virtual environment on your own in **SECTION 3** of this lab to answer a set of questions and challenges that allow you to use the skills you learned in the lab to conduct independent, unguided work - similar to what you will encounter in a real-world situation.

Learning Objectives

Upon completing this lab, you will be able to:

1. Implement centrally managed password settings in accordance with a password protection policy.
2. Implement centrally managed virus detection and protection in accordance with an antivirus policy.

Implementing an IT Security Policy (4e)

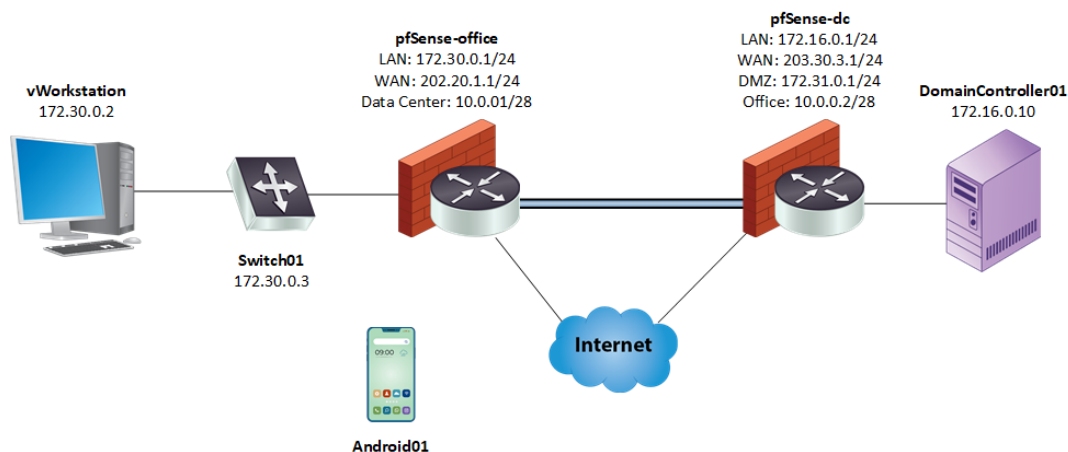
Fundamentals of Information Systems Security, Fourth Edition - Lab 07

3. Apply a Microsoft-issued Windows Security Baseline to enforce best-practice security controls for a Windows Server system.
4. Implement a standard for mobile device security controls in accordance with a BYOD device policy.
5. Define best practices for Acceptable Use Policies and Privacy Policies.

Topology

This lab contains the following virtual machines. Please refer to the network topology diagram below.

- vWorkstation (Windows: Server 2022)
- Switch01 (Linux: Debian 11)
- pfSense-office (FreeBSD: pfSense)
- pfSense-dc (FreeBSD: pfSense)
- DomainController01 (Windows: Server 2019)
- Android01 (Android OS)



Tools and Software

The following software and/or utilities are required to complete this lab. Students are encouraged to

explore the Internet to learn more about the products and tools used in this lab.

- Group Policy Management Console (GPMC)
- Activity Directory Users and Groups
- Windows Defender Antivirus
- Security Compliance Toolkit (SCT)

Deliverables

Upon completion of this lab, you are required to provide the following deliverables to your instructor:

SECTION 1

1. Lab Report file, including screen captures of the following:

- Newly configured Domain Password Policy settings
- Successful password change message
- Logged on user account
- Newly configured Domain Real-time protection Policy settings
- Greyed-out real-time threat protection settings

2. Any additional information as directed by the lab:

- None

SECTION 2

1. Lab Report file, including screen captures of the following:

- Microsoft's recommended Password and Account Lockout policy settings.
- Linked MSDomainSecurity2019 object.
- Password and Account Lockout policy settings.

2. Any additional information as directed by the lab:

- Results of the Google Play Protect scan.
- Updated "last successful check for update" timestamp.
- Android lock screen.
- Encryption set-up explanation.
- Find My Device settings.

SECTION 3

1. Lab Report file, including screen captures of the following:

- None

2. Any additional information as directed by the lab:

- Using the Internet, research Acceptable Use Policies, then identify at least five common policy statements and explain their significance. Be sure to cite your sources.
- Using the Internet, research user Privacy Policies, then identify at least five common policy statements and explain their significance. Be sure to cite your sources.

Section 1: Hands-On Demonstration

Note: In this section of the lab, you will follow a step-by-step walkthrough of the objectives for this lab to produce the expected deliverables.

1. Review the Tutorial.

Frequently performed tasks, such as making screen captures and downloading your Lab Report, are explained in the Cloud Lab Tutorial. The Cloud Lab Tutorial is available from the User menu in the upper-right corner of the Student Dashboard. You should review these tasks before starting the lab.

2. Proceed with Part 1.

Part 1: Implement a Password Protection Policy

Note: In this part of the lab, you will implement a password protection policy. A password protection policy defines the rules for password validity and management within an organization. A password policy will likely include the minimum complexity of allowed passwords, how long passwords are valid, how users change their passwords, and how to handle forgotten passwords. Although enforcing traditional complexity requirements (for example, mixed case characters, inclusions of numeric and other special characters, etc.) is often debated, most organizations still require that passwords adhere to complexity standards.

A simple password policy might look something like this:

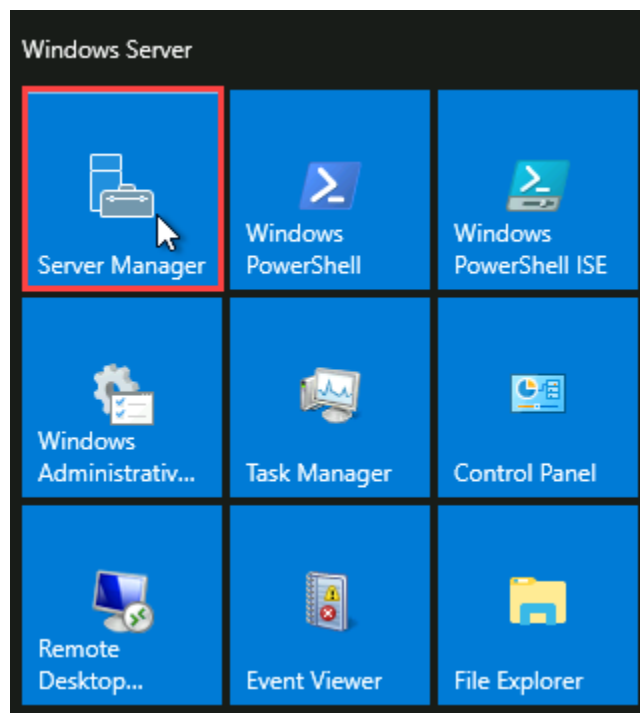
All passwords at Secure Labs on Demand must adhere to the following rules:

- 1. Passwords must be at least 9 characters in length and must contain at least 3 of the following: Upper case characters, lower case characters, numeric characters, special characters (@%+\'!/#\$^?.,(){}[]-_.).*
- 2. Passwords expire every 30 days, requiring users to change their passwords to a new password that adheres to complexity requirements and is different from any of the previously used 15 passwords.*
- 3. Users can follow a self-service password reset request process to change a password on demand (to recover from a lost password) or upon password expiration.*

In Microsoft Windows environments, IT administrators and security practitioners can efficiently enforce IT security policies, including password policies, using Active Directory. Active Directory serves as a centralized record of users, devices, and settings, wherein administrators can define password policy requirements once and apply those requirements to multiple users across a domain. These collections of settings in Active Directory are referred to as Group Policy Objects (GPO), which domain administrators can manage using the Group Policy Management Console on a Windows Domain Controller.

In the next steps, you will access the domain controller for this lab environment and access the Group Policy Management Console.

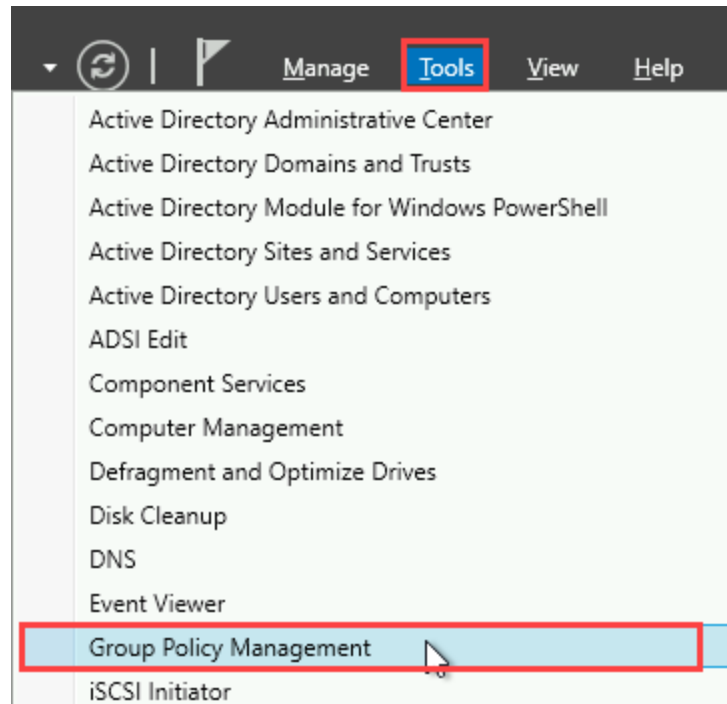
1. On the Lab View toolbar, **select DomainController01** from the Virtual Machine menu to connect to the DomainController01 system.
2. On the DomainController01 taskbar, **click the Windows Start icon**, then **click the Server Manager button** to open the Server Manager application.



Server Manager icon

3. From the Server Manager menu bar, **select Tools > Group Policy Management** to open the Group Policy Management Console.

You may need to click the flashing icon on the taskbar to display the Group Policy Management Console.

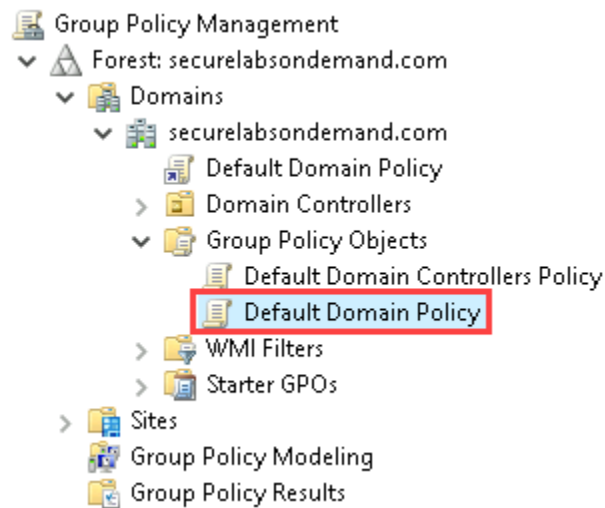


Tools > Group Policy Management

Note: The Group Policy Management Console (GPMC) is the primary interface used to manage GPOs and settings that apply across an organization. Notice that the folders are organized by forests (a collection of one or more domains), then by domains within the forest. If you select a domain, such as `securelabsondemand.com`, and then select Group Policy Objects, you will see a list of GPOs for that domain. This is where you will define new GPOs and instruct Active Directory when, where, and how to deploy each one.

4. In the left pane of the Group Policy Management Console, **navigate to Forest: `securelabsondemand.com` > Domains > `securelabsondemand.com` > Group Policy**

Objects > Default Domain Policy to open the Default Domain Policy.



Default Domain Policy

Note: Active Directory provides the flexibility to manage organizations of all sizes. As most organizations grow, they develop organizational groups, such as departments or functional areas, that need to be managed differently than other groups. Active Directory helps organizations align their IT infrastructure to their internal organization using forests, domains, and GPOs.

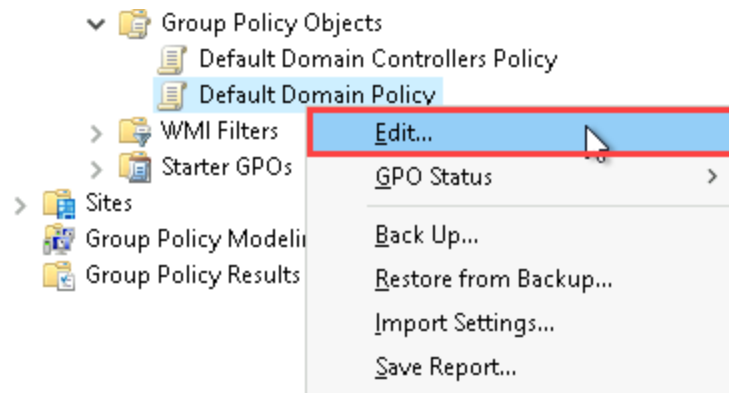
You have already seen that a forest is a collection of domains. An example of a forest could be Operations, which consists of Manufacturing, Warehousing, and Shipping, each of which could be defined as a domain. This approach makes it easy to apply settings across all of Operations or just to one or two domains. You can link GPOs to one or more domains or to organizational units (OUs) defined within a domain.

To get you started, Microsoft provides the Default Domain Policy, which specifies common (and generally secure) settings to use as a starting point. You can see the settings in the Default Domain Policy by selecting Default Domain Policy under your chosen domain in the GPMC, and then selecting the Settings tab. Settings in the Default Domain Policy are applied to all computers and users unless they are overridden with more specific GPOs.

In the next steps, you will open the Default Domain Policy object in the Group Policy Management Editor and make changes to the password policy settings.

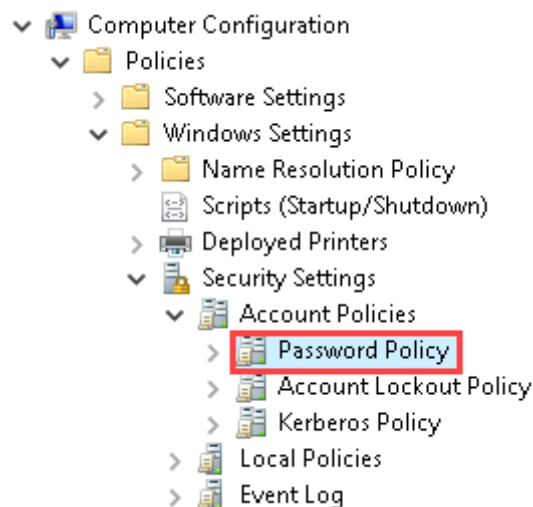
5. In the left pane of the Group Policy Management window, **right-click** the **Default Domain**

Policy object and **select Edit** from the context menu to open the Group Policy Management Editor.



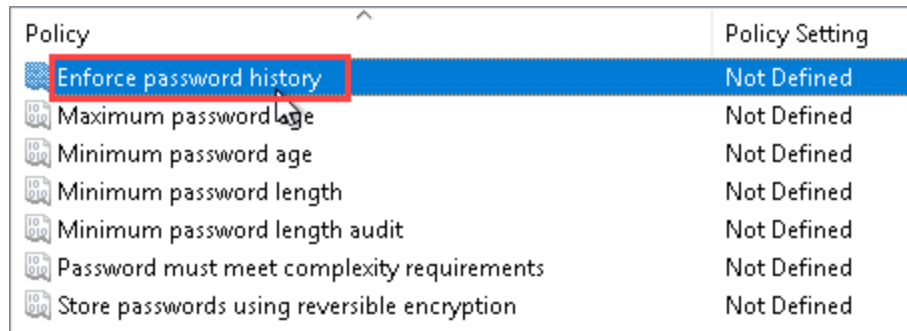
Edit the Default Domain Policy object

6. In the left pane of the Group Policy Management Editor, **navigate to Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy** to open the Password Policy settings.



Password Policy

7. In the right pane of the Group Policy Management Editor, **double-click Enforce password history** to open the Enforce password history Properties dialog box.

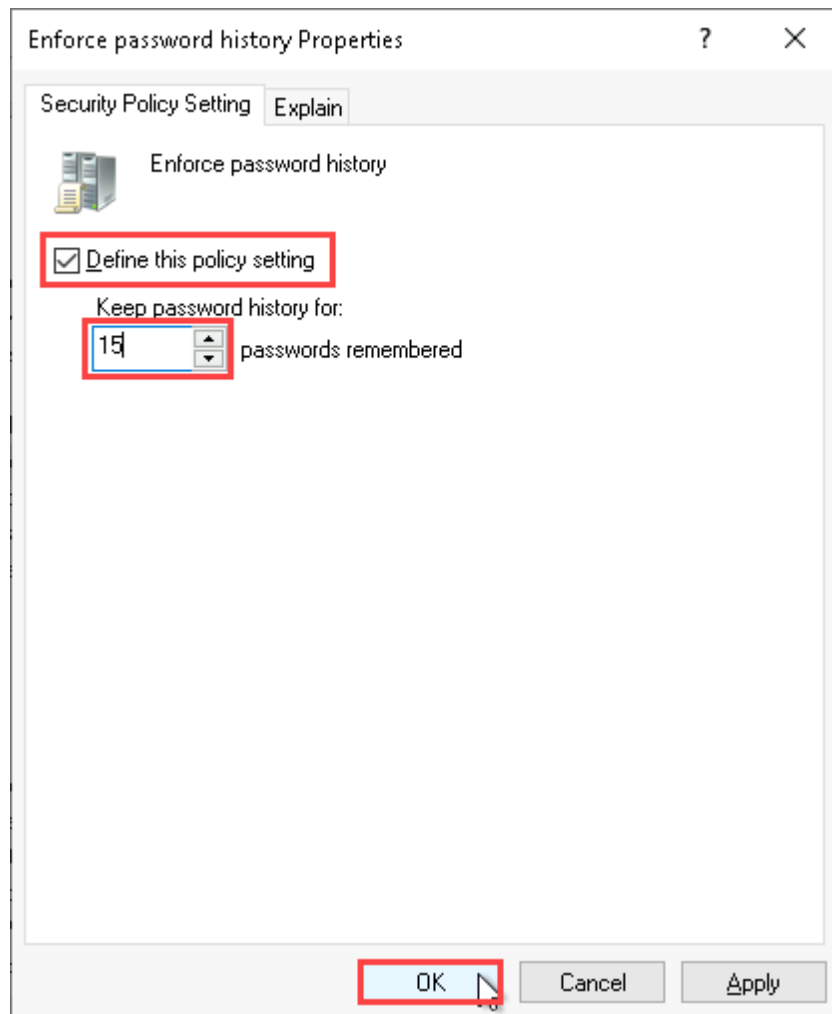


Policy	Policy Setting
Enforce password history	Not Defined
Maximum password age	Not Defined
Minimum password age	Not Defined
Minimum password length	Not Defined
Minimum password length audit	Not Defined
Password must meet complexity requirements	Not Defined
Store passwords using reversible encryption	Not Defined

Enforce password history

Note: This setting tells AD to remember old passwords, up to the number specified, and to prevent users from re-using any old passwords. You can use this setting to satisfy the policy requirement from the sample policy that disallows re-using any of the previous 15 passwords.

8. In the Properties dialog box, **click the Define this policy setting checkbox**, then **type 15** in the *Keep password history for* box and **click OK** to save the change.



Enforce password history

9. In the right pane of the Group Policy Management Editor, **double-click Maximum password age** to open the Maximum password age Properties dialog box.

Note: This setting tells Active Directory that passwords are only valid for a specific number of days and must be changed when the limit is reached. You can use this setting to satisfy the policy requirement from the sample policy that requires passwords to expire (must be changed) every 30 days.

10. In the Properties dialog box, **click the Define this policy setting checkbox**, then **type 30** in the *Password will expire in* box and **click OK** to save the change.

Note: Because the minimum password age, a related policy, is currently undefined, the Group Policy Manager will automatically suggest a value.

11. When prompted, **click OK** to accept the suggested change.
12. In the right pane of the Group Policy Management Editor, **double-click Minimum password length** to open the Minimum password length Properties dialog box.

Note: This setting tells Active Directory what the minimum acceptable password length is. In other words, passwords must contain at least the number of characters specified by this setting. You can use this setting to satisfy the policy requirement from the sample policy that requires passwords to be at least 9 characters in length.

13. In the Properties dialog box, **type 9** in the *Password must be at least* box, then **click OK** to save the change.
14. In the right pane of the Group Policy Management Editor, **double-click Password must meet complexity requirements** to open the Properties dialog box.
15. In the Properties dialog box, **click the Define this policy setting checkbox** and **click the Enabled radio button**, then **click OK** to save the change.
16. **Make a screen capture** showing the **newly configured Domain Password Policy settings**.

Note: In the previous steps, you made changes to the password policy. In order to see the changes take effect in the lab, you will need to force an update of all group policies, then reset the password for a sample user account. You will make that change in the Active Directory Users and Computers console.

17. **Close the Group Policy Management Editor.**
18. On the DomainController01 taskbar, **click the PowerShell icon** to open the PowerShell application.



PowerShell icon

19. At the PowerShell prompt, **type `gpupdate /force`** and **press Enter** to force an immediate update of all Group Policies on the domain controller.

```
PS C:\Users\Administrator> gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.

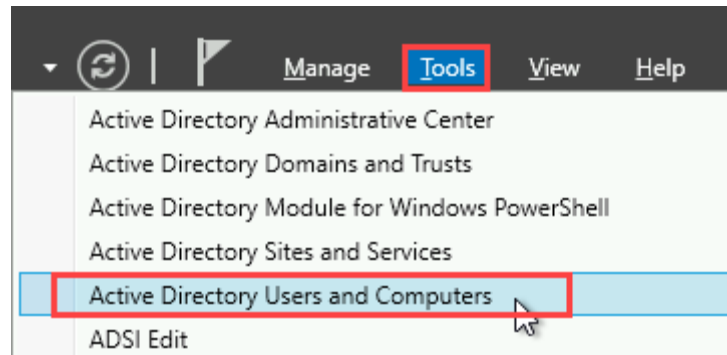
PS C:\Users\Administrator> █
```

Force an update of all Group Policies

Note: The system will generate a confirmation message indicating that Computer and User Policy updates have been completed successfully.

20. **Minimize the PowerShell window.**
21. On the DomainController01 taskbar, **click the Server Manager icon** to restore the Server Manager window.

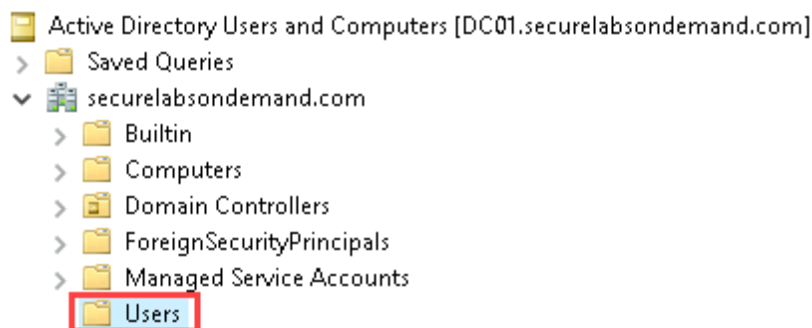
22. On the Server Manager menu bar, **click Tools** and **select Active Directory Users and Computers** to open the Active Directory Users and Computers console.



Tools > Active Directory Users and Computers

Note: The Active Directory Users and Computers tool allows domain administrators to manage identities across an AD environment. Identities are separated between computers, which includes computers and devices in a domain, and users, which represents both user accounts and groups in AD. This tool provides administrators with the ability to add, delete, and modify users, groups, and computers, as well as carry out management tasks, such as adding users or computers to one or more groups.

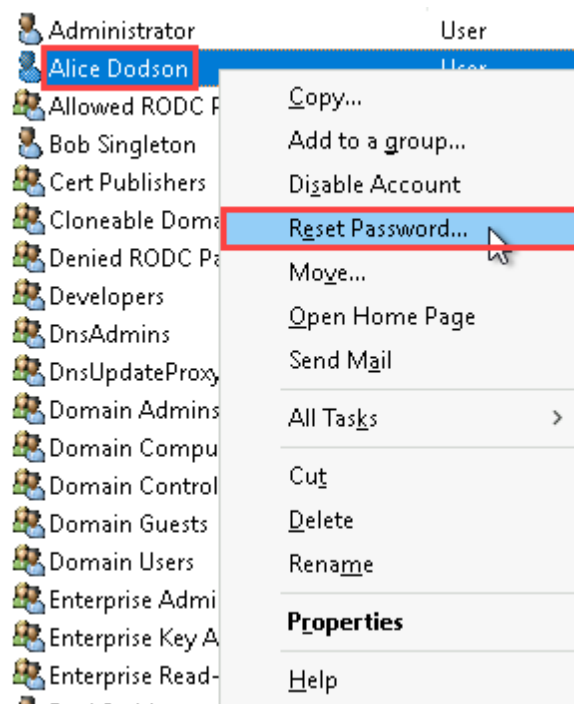
23. In the left pane of the Active Directory Users and Computers window, **navigate to securelabsondemand.com > Users** to view users in the securelabsondemand.com domain.



Users container

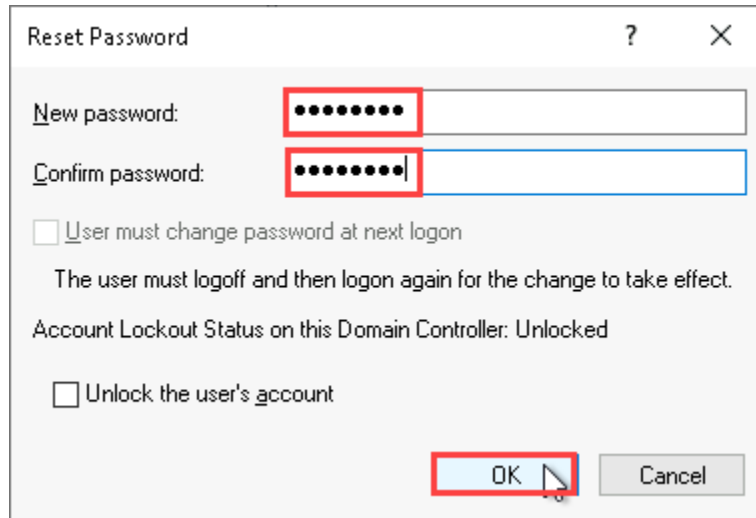
Note: Active Directory provides two units used for grouping identities together. The first is Containers. Containers look like folders in a tool like File Explorer that list entities, like users or computers, that are related by function. The second is Organizational Units (OUs). Organizational Units let you group objects such as user accounts, service accounts, or computer accounts. You can use OUs to apply GPOs to enforce configuration settings for specific groups.

24. In the right pane of the Active Directory Users and Computers window, **right-click** the **Alice Dodson** user and **select Reset Password** from the context menu.



Reset Password

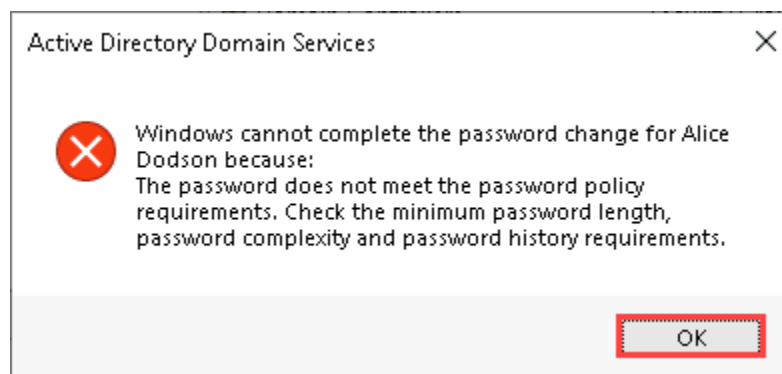
25. In the Reset Password dialog box, **type P@ssw0rd**, a new password, in both the password boxes, then **click OK** to change the password.



Reset Password dialog box

Note: The system will generate an error message because this password is only 8 characters long and does not meet the new password requirements.

26. **Click OK** to dismiss the error message.



Password requirements error message

27. **Repeat steps 24-25** using another new password: **P@ssw0rd!2**.

Note: This password meets the new requirements, so the system will generate a success message.

28. **Make a screen capture** showing the **successful password change message**.

29. **Click OK** to dismiss the message.

30. **Close** the **Active Directory Users and Computer window**.

31. From the DomainController01 taskbar, **restore** the **Group Policy Management window**.

Note: Notice that the Enforced and Link enabled settings are both set to Yes. The Link enabled setting states whether the settings in this policy are applied to the linked entities. In this case, the policy is linked to the securelabsondemand.com domain, and since the Link enabled setting is Yes, all of the settings in the policy will be applied to the specified domain.

Active Directory allows granular GPOs (linked to an OU or computer, local, etc.) to override settings in the Default Domain Policy by specifying that a GPO does not inherit settings from a higher-level GPO. Assigning the Enforced setting a value of Yes will disable inheritance for lower-level GPOs, which will block lower-level GPOs from overriding a setting in the Default Domain Policy. In many production environments, the Default Domain Policy contains settings that should apply to an entire organization, while more granular GPOs are created and linked to OUs, computers, groups, or even users and configured to override the Default Domain Policy settings. This multilayered approach to policy management provides a flexible way to enforce global settings and still allow flexibility to tailor settings for specific needs. For the purposes of this lab, you will limit your changes to the Default Domain Policy in the interest of demonstrating how individual policy requirements can be centrally managed.

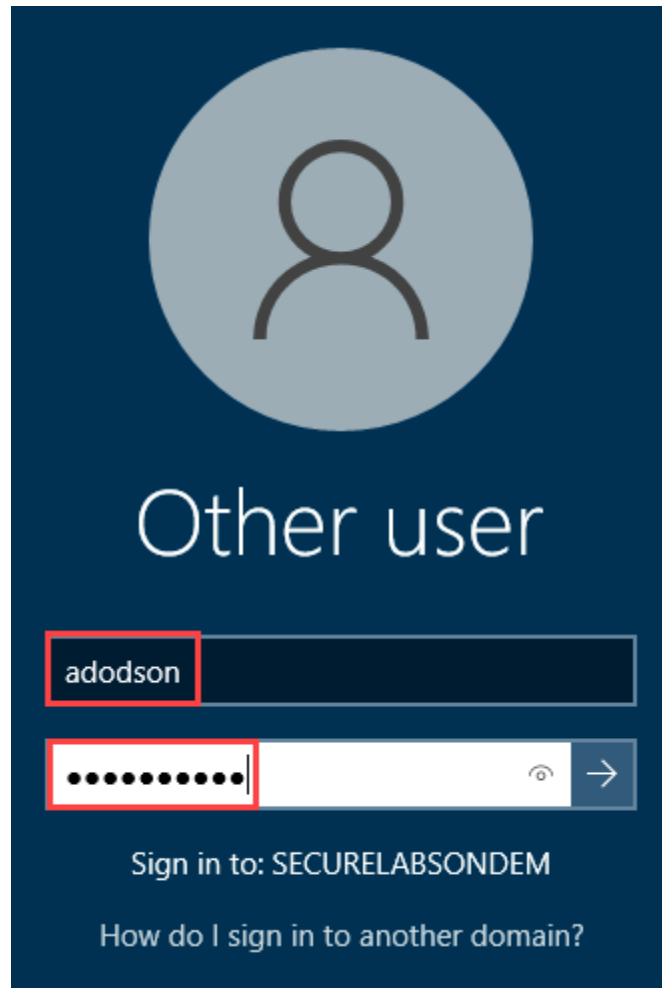
32. **Close** any **open windows**.

Note: In the next steps, you will log on to the vWorkstation machine, which is a member of the securelabsondemand.com domain for which you just changed the password policies.

33. On the Lab View toolbar, **select vWorkstation** from the Virtual Machine drop-down menu to connect to the vWorkstation.
34. At the vWorkstation log-in screen, **click Other user**, then **type** the following credentials and **press Enter** to log in using the new Alice Dodson password.

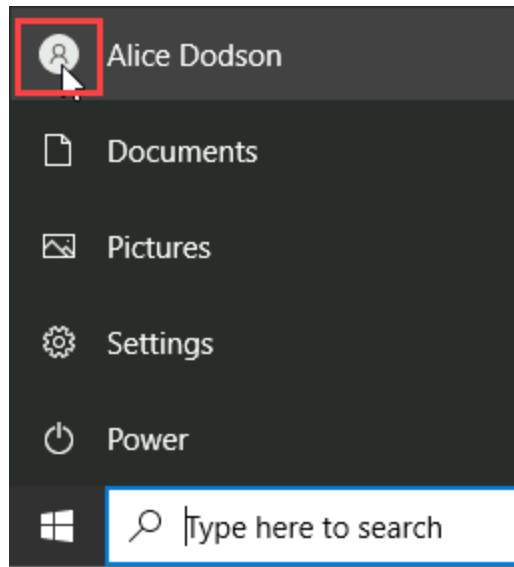
Username: **adodson**

Password: **P@ssw0rd!2**



Log in as Alice Dodson

35. On the vWorkstation taskbar, **click the Windows Start icon** and **hover your cursor** over the **User icon** to display the current user.



Current user

36. **Make a screen capture** showing the **logged on user account**.

Note: While passwords such as *P@ssw0rd!* or *!dr0wss@P* meet all of the new password requirements, they also demonstrate that it is still possible to make a new password that is very similar to an old one by simply reversing the order or appending characters to the end of a base password, such as *P@ssw0rd*. Retaining a base password may be easy for users to remember, but it also makes it easier for a hacker to crack once they've determined the base password. User security education and user policy adoption are critical in any organization because the best security control is a willing and educated end user.

Part 2: Implement an Antivirus Policy

Note: In this part of the lab, you will implement an antivirus policy. An antivirus policy states how an organization will implement controls to combat viruses and other malware. The antivirus policy sets the rules for determining what settings users can change from the default antivirus settings and whether controls must be present (and in what state) on each device.

A simple antivirus policy might look something like this:

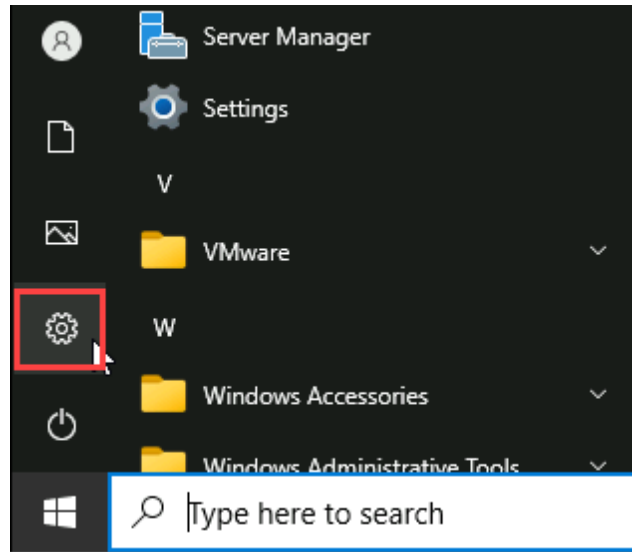
All computers and devices must have approved, and current antivirus/antimalware software installed and active at all times. The following requirements must be met for all computers and devices that

connect the organization's network:

1. *Organization-wide antivirus settings will be enforced using AD and local overrides are not allowed.*
2. *Approved 3rd-party antivirus/antimalware solutions are allowed, but only in addition to the use of Microsoft Defender.*
3. *All antivirus/antimalware solutions in use must be updated to the latest available software version and using the latest available signature databases.*

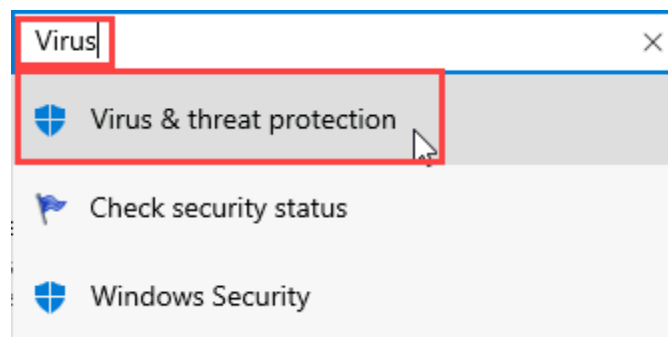
As mentioned in the sample policy above, you will use Windows Defender Antivirus (also known as Windows Security). Windows Defender Antivirus is a comprehensive anti-malware software solution that protects computers and devices running Windows from spyware, viruses, and many other types of malware. Windows Defender Antivirus is a part of the Windows operating system, which makes automatic updates and settings management through Active Directory easy and transparent. Although Windows Defender Antivirus is easily managed across an organization using Active Directory, it is not the only enterprise antivirus solution. Many vendors offer commercial antivirus solutions that also support central management using AD for endpoint protection.

1. On the vWorkstation taskbar, **click the Windows Start icon** and **click the Settings icon** to open the Settings window.



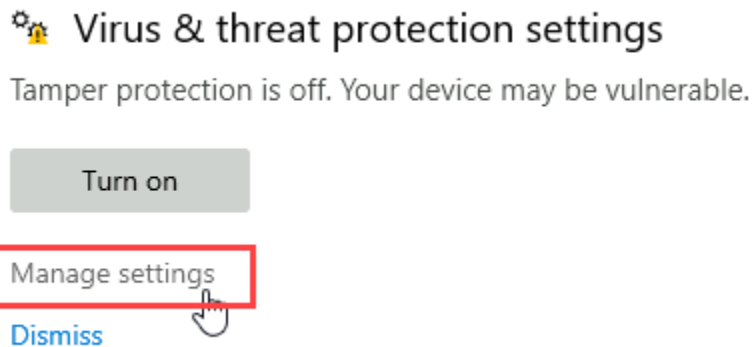
Settings icon

2. In the Settings window, **type Virus** in the Search field, then **select the Virus & threat protection** from the results to open the Virus & threat protection page.



Search for Virus & threat protection

3. On the Virus & threat protection settings page, under the Virus & threat protection settings header, **click the Manage settings link** to open the Virus & threat protection settings page.



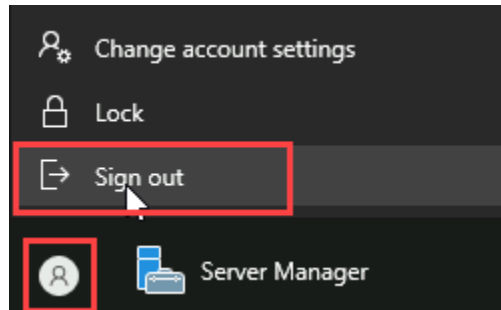
Manage settings

4. On the Virus & threat protection settings page, **attempt to deactivate** the Real-time protection, Cloud-delivered protection, and Tamper Protection settings.

Note: Even though it looks like you can turn off real-time, cloud-delivered, and tamper protection, you cannot. The administrator set up a policy that blocks users from changing these settings. If you toggle any of these values, the switch immediately goes back to its previous setting. By disallowing users the ability to turn off important protections, administrators do not have to wonder if devices are protected.

In this case, these settings are currently managed by the local administrator of the vWorkstation. The main problem with local management is that administrators must sign into each individual computer to change any setting. If an organization decides to change one or more settings across every computer, administrators will have to manually make that change for every locally managed computer. Central administration using AD makes it easy to change a setting once and let AD deploy it to many computers automatically. In the next steps, you will use the Group Policy Management Console to manage specific Windows Defender settings centrally from the domain controller.

5. On the vWorkstation taskbar, **click** the **Start icon**, then **click** the **User icon** and **select Sign Out** to log out of the adodson account.

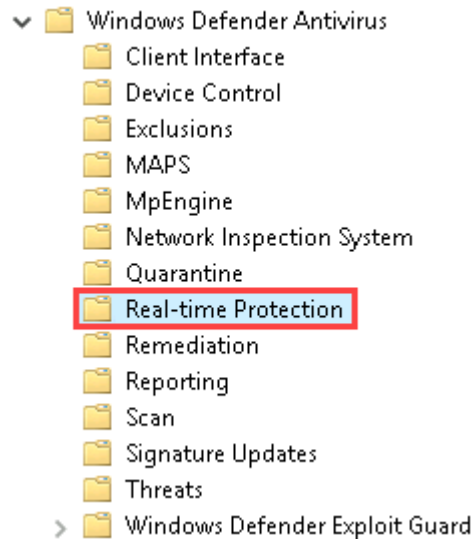


Sign out

6. On the Lab View toolbar, **select DomainController01** from the Virtual Machine menu to connect to the DomainController01 system.
7. On the DomainController01 taskbar, **click the Windows Start icon**, then **click the Server Manager button** to open the Server Manager application.
8. From the Server Manager menu bar, **select Tools > Group Policy Management** to open the Group Policy Management Console.

You may need to click the flashing icon on the taskbar to display the Group Policy Management Console.

9. In the left pane of the Group Policy Management Console, **navigate to Forest: securelabsondemand.com > Domains > securelabsondemand.com > Group Policy Objects > Default Domain Policy** to display the Default Domain Policy.
10. In the left pane of the Group Policy Management window, **right-click the Default Domain Policy link** and **select Edit** from the context menu to open the Group Policy Management Editor.
11. In the left pane of the Group Policy Management Editor, **navigate to Computer Configuration > Policies > Administrative Templates: Policy definitions (ADMX files) retrieved from the local computer > Windows Components > Windows Defender Antivirus > Real-time protection** to open the Real-time protection settings.



Real-time Protection

Note: For the purposes of this lab, you will only modify a few Group Policy settings for Windows Defender Antivirus in order to demonstrate the capabilities of Group Policy centrally managing antivirus settings across a domain. Fully configuring the Windows Defender Antivirus policy settings manually is outside the scope of this lab, as there are 100+ individual settings associated with Windows Defender. Attempting to change many settings to match a desired state across an organization is a situation where you would benefit from using Microsoft Security Baselines. A Security Baseline is a collection of settings that administrators can quickly and easily use to create GPOs to modify settings. You will learn more about Security Baselines in Section 2.

In the next steps, you will ensure that real-time protection is always on and cannot be overridden by other users, such as local administrators. Real-time protection monitors incoming data, such as received email messages and downloaded files, to ensure any data with embedded malware is blocked before it can cause damage. Real-time protection is sometimes called an antivirus or anti-malware shield and is an important component in an anti-malware strategy.

12. In the right pane of the Group Policy Management Editor, **double-click "Turn off real-time protection"** to open the Properties dialog box.

Setting	State
 Turn off real-time protection	Not configured
 Turn on behavior monitoring	Not configured
 Scan all downloaded files and attachments	Not configured
 Monitor file and program activity on your computer	Not configured

Group Policy Management Editor

13. In the Properties dialog box, **click the Disabled radio button** and **click OK** to save the change.



Disable real-time protection

14. In the right pane of the Group Policy Management Editor, **double-click Configure local setting override to turn on real-time protection** to open the Properties dialog box.
15. In the Properties dialog box, **click the Disabled radio button** and **click OK** to save the change.
16. **Make a screen capture** showing the **newly configured Domain Real-time protection Policy settings**.

17. On the DomainController01 taskbar, **click** the **Windows PowerShell button** to open the PowerShell application.
18. At the PowerShell prompt, **type** **gpupdate /force** and **press Enter** to force an immediate update of all Group Policies on the domain controller.
19. **Close** any **open windows**.
20. On the Lab View toolbar, **select vWorkstation** from the Virtual Machine menu to connect to the vWorkstation.
21. At the vWorkstation log-in screen, **click Other user**, then **type** the following credentials and **press Enter** to log in using the adodson account.

Username: **adodson**
Password: **P@ssw0rd!2**
22. On the vWorkstation taskbar, **click** the **Windows PowerShell button** to open the PowerShell application.
23. At the PowerShell prompt, **type** **gpupdate /force** and **press Enter** to force an immediate update of all Group Policies on the domain-joined vWorkstation.
24. **Repeat steps 2-3** to return to the Virus & threat protection settings page.

Note: You should now see that real-time threat protection settings are grayed out. This is because they are now being managed centrally by the domain controller.

The steps you have taken in this lab are only one small part of a complete antivirus solution. Additional steps for enforcing an antivirus policy should include mandating periodic scans, dictating minimum allowed antivirus software versions, and limiting software that users can install and types of files they can download. There are many other controls that can help combat malware as well. Keep in mind that the central point of this section is to stress that antivirus efforts should be centrally managed by an organization, rather than relying on individual users to regularly carry out tasks like running scans, examining incoming data, and validating antivirus signature databases.

25. **Make a screen capture** showing the **grayed-out real-time threat protection settings**.
26. **Close** any open **windows**.

Note: This concludes Section 1 of the lab.

Section 2: Applied Learning

Note: **SECTION 2** of this lab allows you to apply what you learned in **SECTION 1** with less guidance and different deliverables, as well as some expanded tasks and alternative methods. You will implement multiple policies using a Windows security baseline and configure an Android mobile device to comply with a mobile device security policy.

Part 1: Apply a Windows Security Baseline

Note: In this part of the lab, you will learn a more efficient method of implementing a password protection policy, as well as other domain-level policy positions that can be implemented using Active Directory and the Group Policy Management Console.

As part of its Security Compliance Toolkit, Microsoft periodically releases new security baselines for each of its operating systems. In its most basic form, a security baseline is simply a collection of configuration settings used for managing security. A Microsoft-issued Windows security baseline is a group of recommended configuration settings for the Windows operating system, based on feedback sourced from Microsoft security engineering teams, partners, and customers. Windows security baselines consist of multiple Group Policy Objects (GPOs), which contain the latest recommended settings for secure Windows environments. Security-conscious administrators can use Windows security baselines in tandem with auditing tools such as the Policy Analyzer to compare their existing configuration settings with Microsoft's latest security recommendations, then make specific changes as needed to harden their Group Policy settings. Windows GPOs can also be imported directly into the Microsoft Group Policy Management Console, edited to meet an organization's unique needs, and deployed directly to production IT environments.

In the next steps, you will use the Group Policy Management Console on DomainController01 to create a new GPO, import a Domain Security baseline for Server 2019 from the Security Compliance Toolkit, and link the new GPO to the securelabsondemand.com domain.

1. On the Lab View toolbar, **select DomainController01** from the Virtual Machine menu.
2. From the DomainController01 taskbar, **open the File Explorer**.
3. In the File Explorer, **navigate** to the **C:\SCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\GP Reports** folder.
4. In the File Explorer, **double-click the MSFT Windows 10 1809 and Server 2019 - Domain Security.htm file** to open the Group Policy report for Microsoft's recommended domain security policies.

5. In the Group Policy Report, **locate** the **Password** and **Account Lockout Policy** settings.

Computer Configuration (Enabled)		hide
Policies		hide
Windows Settings		hide
Security Settings		hide
Account Policies/Password Policy		hide
Policy	Setting	
Enforce password history	24 passwords remembered	
Maximum password age	60 days	
Minimum password age	1 days	
Minimum password length	14 characters	
Password must meet complexity requirements	Enabled	
Store passwords using reversible encryption	Disabled	
Account Policies/Account Lockout Policy		hide
Policy	Setting	
Account lockout duration	15 minutes	
Account lockout threshold	10 invalid logon attempts	
Reset account lockout counter after	15 minutes	
User Configuration (Disabled)		hide
No settings defined.		

Group Policy Report

Note: The password policy you saw in Section 1 was primarily designed to ensure that users create password that are difficult to guess. One way that attackers try to compromise passwords is to use automation to try different passwords to sign into a user account. This type of attack generates many failed sign-in attempts and is easy to detect (if you are looking for it). An account lockout policy states requirements for GPO settings that help prevent attackers using automated techniques to compromise passwords. Active Directory GPOs make it easy to lock an account temporarily if Windows detects too many failed sign in attempts. Settings that administrators can change include: when to lock an account (the failed sign in attempts threshold), how long to lock the account, and how long to wait until the count of failed sign-in attempts is reset to 0.

6. **Make a screen capture** showing **Microsoft's recommended Password and Account Lockout policy settings**.

7. **Close** the **Domain Security GPO Report** and **File Explorer**.

8. **Open** the **Server Manager** and **launch** the **Group Policy Management Console**.

You may need to click the flashing icon on the taskbar to display the Group Policy Management Console.

9. In the Group Policy Management Console, **right-click** the **Group Policy Objects folder** for the securelabsondemand.com domain and **select New**, then **create** a new Group Policy Object titled MSDomainSecurity2019.

10. In the Group Policy Management Console, **right-click** the new **MSDomainSecurity2019 object** and **select Import Settings** from the context menu to open the Import Settings Wizard.

11. In the Import Settings Wizard, **click Next** to continue to the Backup GPO page.

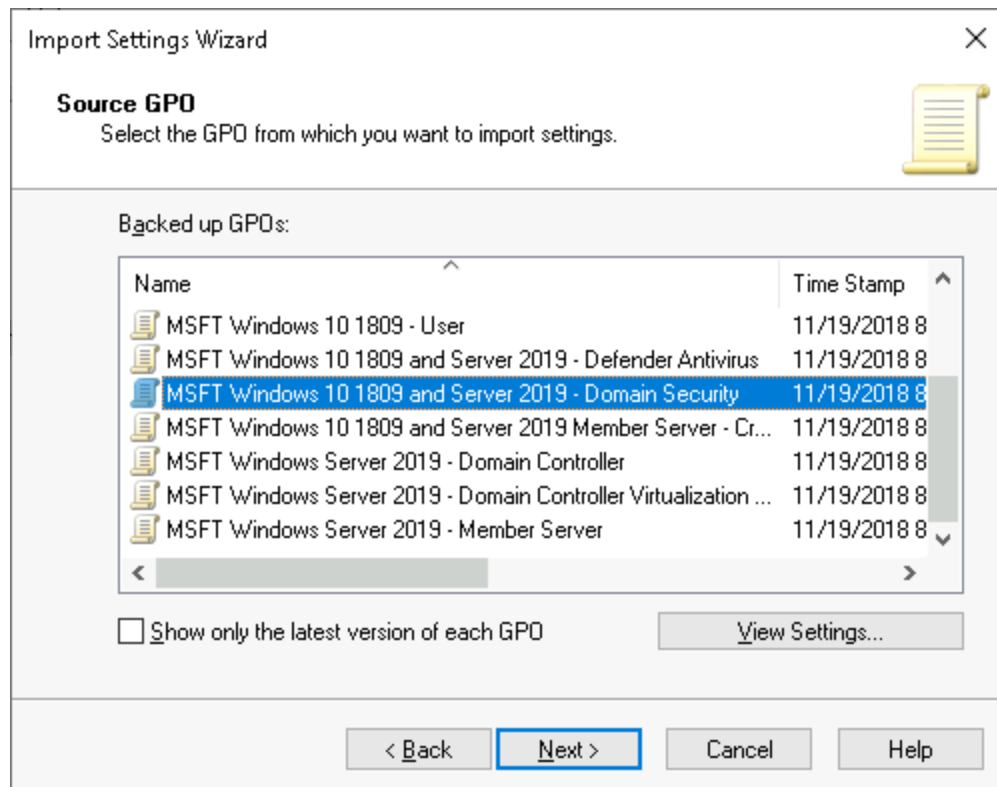
12. On the Backup GPO page, **click Next** to continue without backing up your current GPO.

Note: Typically, backing up your current GPO before importing a new one is considered a best practice, but because this is an empty GPO that you just created, you will not back it up at this time.

13. On the Backup location page, **click** the **Browse button**, then **navigate** to the **C:\SCT\Windows 10 Version 1809 and Windows Server 2019 Security Baseline\GPOs folder** and **click OK** to import the available GPOs to the Import Settings Wizard.

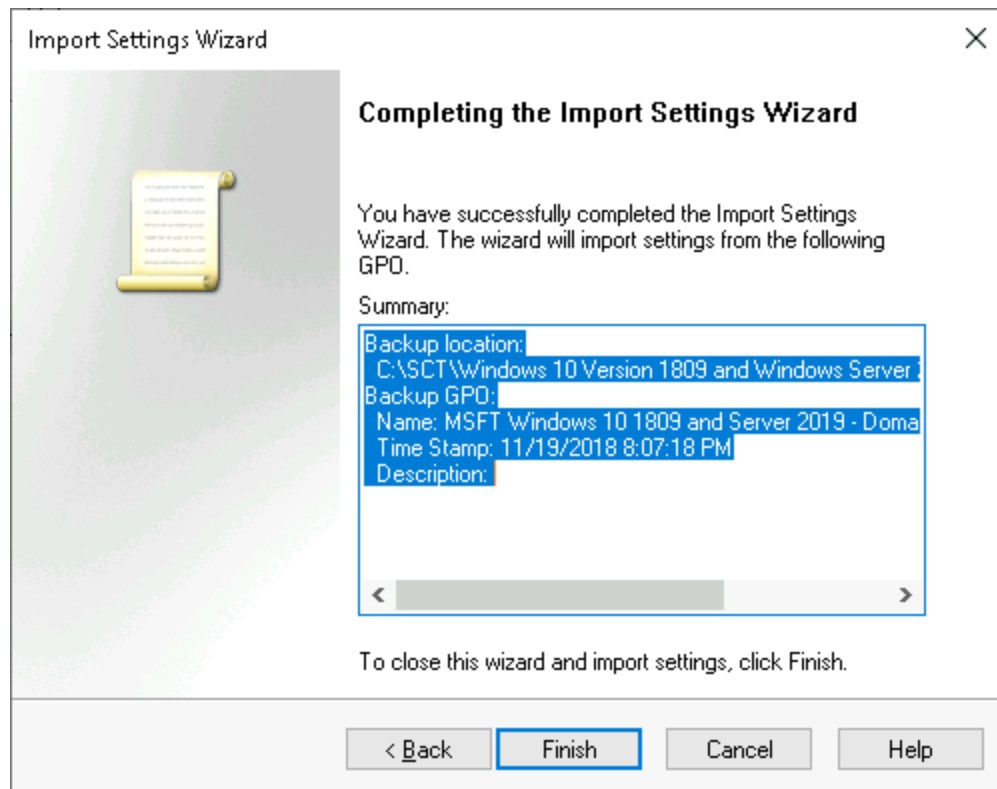
14. On the Backup location Folder page, **click Next** to continue to the Source GPO page.

15. On the Source GPO page, **select** the **MSFT Windows 10 1809 and Server 2019 - Domain Security GPO** and **click Next** to continue to the Scanning Backup page.



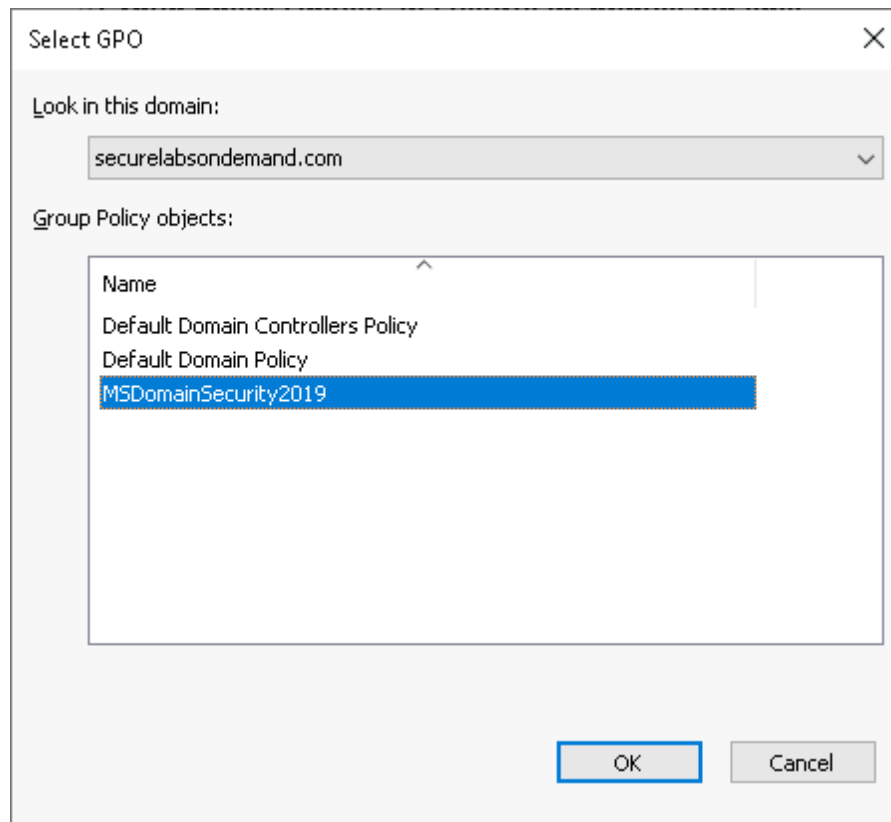
MSFT Windows 10 1809 and Server 2019 - Domain Security

16. When the scan of the GPO backup file is complete, **click Next** to continue to the Summary page.
17. On the Summary page, **click Finish** to close the Import Settings Wizard, then **click OK** to close the Import progress dialog box.



Summary page

18. In the Group Policy Management Console, **right-click** the **securelabsondemand.com** domain and **select Link an Existing GPO**, then **select** the **MSDomainSecurity2019** GPO and **click OK** to link the new GPO to the domain for this lab environment.



Select the MSDomainSecurity2019 GPO

19. **Make a screen capture** showing the **linked MSDomainSecurity2019 object**.
20. In the Group Policy Management Console, **right-click** the **MSDomainSecurity2019 object** and **select Save Report** to open the Save GPO Report dialog box.
21. **Save** the GPO Report to the DomainController01 desktop as **MSDomainSecurity2019_report**.
22. **Open** the **MSDomainSecurity2019_report** and **locate** the **Password** and **Account Lockout policy settings**.
23. **Make a screen capture** showing the **Password and Account Lockout policy settings**.

24. Close any open windows.

Part 2: Implement a Mobile Device Security Policy

Note: In this part of the lab, you will implement a mobile device security policy. Prior to the common use of wireless connectivity and mobile devices, organizations could rely on a computer's physical location and surrounding physical security controls to build a security strategy. Today's IT environments include many mobile devices that introduce new risk to any organization. Mobile devices often serve both personal and organizational purposes. This dual use often means programs and data exist that are not centrally managed and could allow attackers to compromise devices and gain unauthorized access to organizational resources. Due to the reliance on mobile devices and increasing remote work and connectivity requirements, organizations need a mobile device policy to define requirements that allow mobile devices to connect securely to an organization's networks.

A mobile device policy states the minimal security settings required for a device to connect to the organization's networks. Organizations can create multiple mobile device policies to address the needs of each type of device (Android, iOS, etc.) or a single general policy for all mobile devices.

A simple mobile device policy for Android devices might look something like this:

All devices that run all versions of the Android operating system must adhere to the following rules:

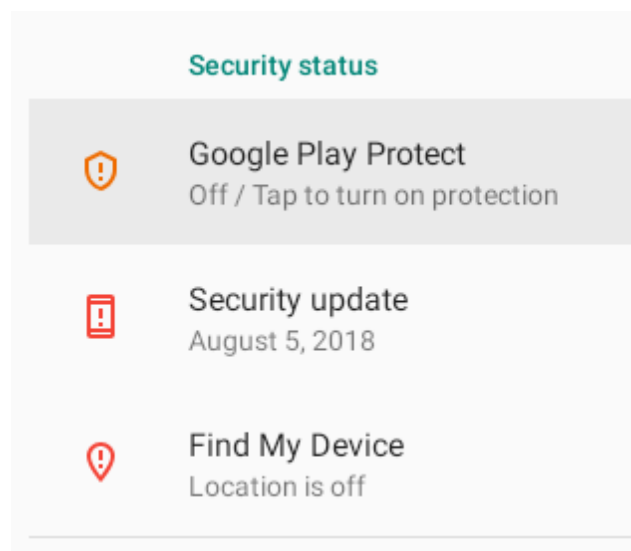
- 1. Devices must enable Google Play Protect and configure to run daily scans.*
- 2. Android mobile device users must check for security updates at least weekly and apply all available updates within 3 days of update discovery.*
- 3. Users must enable Lock screen functionality and protect a locked screen using a password (not a passcode).*
- 4. Users must enable full device encryption to protect data from unauthorized access if the device is lost or stolen.*

In this part of the lab, you will apply several security controls to an Android mobile device in order to comply with the mobile device security policy, including enabling Google Play Protect, regularly checking for security updates, using screen lock, enabling device encryption, and enabling Find My Device.

1. On the Lab View toolbar, **select Android01** from the Virtual Machine menu.
2. At the Android01 home screen, **position your cursor** in the middle of the display's background, then **click and drag up** to simulate the "swipe up" action and open the Apps screen.
3. At the Apps screen, **click the Settings icon** to open the Settings app.
4. In the Settings app, **click Security & location** to open the Security & location settings.

Note: You should see three settings under the Security status section: Google Play Protect, Security update, and Find My Device. Google Play Protect provides antimalware protection for all installed apps, including apps that have been downloaded outside of the Google Play Store. Security update refers to the latest security update that has been applied to this device. Find My Device contains the settings related to Android's Find My Device functionality. In the next steps, you will use Google Play Protect to run a malware scan.

5. In the Security status section, **click Google Play Protect** to open the Google Play Protect settings.



Google Play Protect

6. On the Play Protect page, **click the Turn on button** to activate Google Play Protect.

Note: Play Protect will automatically start a malware scan, which should finish after just a few seconds and confirm that “no harmful apps were found.” Once Play Protect is activated, you can rerun a scan at any time by returning to this screen and clicking the Scan button.

7. **Make a screen capture** showing the **results of the Google Play Protect scan**.

8. At the bottom of the screen, **click the Triangle icon** to return to the Security & location settings.

Note: Installing regular security updates is a critical part of keeping any system secure, and smartphones are no different. In the next steps, you will review the security update settings for this device and manually check for new updates.

9. In the Security status section, **click Security update** to open the Security update settings.
10. On the Security update page, **click Check for update** to query Google’s servers for the latest security patch.



Your system is up to date

Android version: 9

Android security update: August 5, 2018

Last successful check for update at 2:49 PM

→ Check for update

Check for update

Note: A message will display stating that “Your system is up to date.” This is not entirely true. While this version of Android (Version 9) is several years old, Google committed to releasing security patches for Android Version 9 through Fall 2021, and the latest security update appears to be from August 2018. This is a limitation of running a mobile operating system in a virtualized environment and may be disregarded. In practice, you should ensure your smartphone always has access to the latest security updates. While it may be fair to wait a few months to update to major OS releases, knowing that they can sometimes be buggy at launch, you should never wait to install a security update.

11. **Make a screen capture** showing the **updated “last successful check for update” timestamp**.
12. At the bottom of the screen, **click the Triangle icon** to return to the Security & location settings.
13. In the Device security section, **click Screen lock** to open the Screen lock settings.

Note: The different screen lock settings include None, Swipe, Pattern, PIN, and password. Some devices also support biometric features such as fingerprint and facial recognition. None and Swipe offer no actual protection. Pattern, a medium level of security, allows the user to draw a sequence of dots on the display (at least four dots must be connected to complete a pattern). PIN requires the use of a four-digit or higher number and is considered higher security than Pattern. Password requires a combination of at least four numbers and/or letters and is considered the most secure option. Some smartphone manufacturers might argue that their cutting-edge biometric authentication features are more secure, and while this may be technically correct in terms of the unique complexity of the key, the fact of that matter is it is much easier for someone to hold your phone up to your face than it is for them to force you to disclose your password. As usual, multifactor authentication schemes are preferable, but should be balanced against convenience and context.

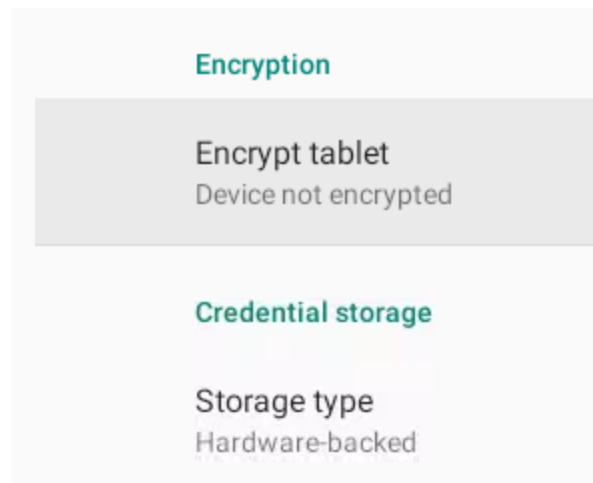
In the next steps, you will configure the Android device to use the Password screen lock. While not the most secure, it will add more protection than the device currently has, and it will be the simplest to implement without an actual touchscreen.

14. On the Choose screen lock page, **click Password** to open the Set screen lock page.
15. On the Set screen lock page, **type P@ssw0rd!**, then **click Next** to continue.
16. On the Re-enter your password page, **type P@ssw0rd!** again, then **click Confirm** to continue.
17. On the Notifications page, **click the Hide sensitive content radio button**, then **click Done** to continue.
18. On the Lab View toolbar, **select Power Cycle** from the System menu to restart the Android VM.
19. **Make a screen capture** showing the **Android lock screen**.
20. **Press the space bar** to simulate the swipe up gesture, then **type P@ssw0rd!** and **press Enter** to unlock the smartphone.
21. **Repeat steps 2-3** to return to the Settings app.

Note: In the final steps, you will enable device encryption and Find My Device on the Android01

mobile device.

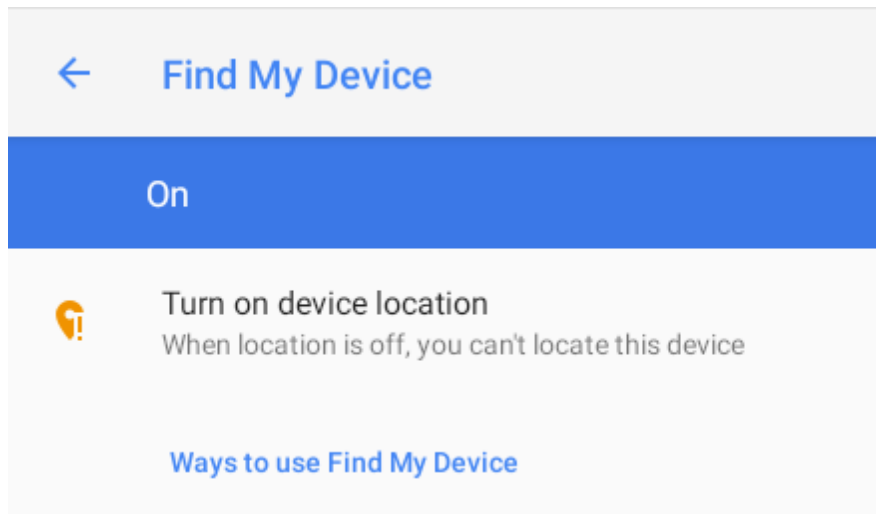
22. From the Android01 home screen, **open** the **Settings app** and **navigate** to the **Security & location settings**.
23. In the Security & location settings, **expand** the **Advanced category**, then **open** the **Encryption & credentials settings**.
24. In the Encryption & credentials settings, **click Encrypt tablet** to enable encryption on this device.



Enable encryption

Note: At this point, you will be prompted with an explanation of the Encrypt feature, followed by a prompt to "Charge your battery and try again." This is yet another restriction of the virtualized environment, so you will not be able to proceed any further. On a real Android device, enabling encryption is one of the strongest security measures you can apply. Without encryption, if your smartphone should fall into the wrong hands, those wrong hands could easily access your data with the right software. That said, even with encryption enabled, sophisticated, well-resourced, and determined actors (government agencies, security companies, and criminal hacking groups) can still bypass that encryption, but the software used in those situations is typically weapons-grade and highly unavailable to the average person.

25. **Make a screen capture** showing the **encryption set-up explanation**.
26. **Return to the Security & location settings**, then **click Find My Device**.



Find My Device

Note: Once again, Find My Device is a feature that cannot be activated due to the restrictions of the virtualized environment. On a real Android device, Find My Device (also known as Android Device Manager) is a powerful security feature that allows you to remotely track, lock, and wipe your Android device. Naturally, wiping your device is a last-resort measure, but in the event that you should lose your phone – or worse, have it stolen – having this feature enabled can provide peace of mind for both you and your employer that any sensitive data will not be easily accessed.

27. **Make a screen capture** showing the **Find My Device settings**.

Note: This concludes Section 2 of the lab.

Section 3: Challenge and Analysis

Note: The following exercises are provided to allow independent, unguided work using the skills you learned earlier in this lab - similar to what you would encounter in a real-world situation.

Part 1: Research Acceptable Use Policies

For the purposes of this exercise, assume you are working as a compliance specialist at the fictional Secure Labs on Demand company. At the instruction of the Chief Information Officer, your team has been tasked with refreshing the organization's Acceptable Use Policy. Before drafting the refreshed policy documentation, you have been asked to conduct research on contemporary best practices for Acceptable Use Policies.

Using the Internet, **research** Acceptable Use Policies, then **identify** at least five common policy statements and **explain** their significance. Be sure to cite your sources.

Part 2: Research Privacy Policies

For the purposes of this exercise, once again assume you are working as a compliance specialist at the fictional Secure Labs on Demand company. At the instruction of the Chief Information Officer, your team has also been tasked with refreshing the organization's user Privacy Policy. Before drafting the refreshed policy documentation, you have been asked to conduct research on contemporary best practices for Privacy Policies.

Using the Internet, **research** user Privacy Policies, then **identify** at least five common policy statements and **explain** their significance. Be sure to cite your sources.

Note: This concludes Section 3 of the lab.